

Business Process: Detecting and Responding to Compromised Employee Accounts

Purpose. Organizations lose money and data when an attacker gets into an employee account and nobody notices until later. This process describes how FRIDAY, a database-level security tool, catches suspicious account activity as it happens, locks the account when the risk is critical, and hands the case to a person to review.

Actors.

- **Employee or attacker:** starts the process by logging in. The attacker may be guessing passwords or logging in at odd hours.
- **FRIDAY:** the Oracle database engine. It records each attempt, scores it, raises alerts and locks accounts through the trigger "trg_quarantine_account". Note that the alerts are stored in a new row created by the trigger, the name of the trigger is " Security_Alerts" . After this the suspicious account's status is changed to being LOCKED.
- **SOC analyst:** the security staff member who reviews alerts, decides whether they are real and can unlock an account.

Process steps.

1. A login attempt or suspicious activity occurs.
2. FRIDAY writes every attempt to Auth_Logs.
3. FRIDAY calculates a risk score, using recent failures, time of day and location.
4. **Decision: is the score critical?** Three failed logins within five minutes reach the critical level.
5. If not, the event stays in the Auth_Logs and the process waits for the next attempt.
6. If critical, FRIDAY writes an alert to Security_Alerts.
7. The trigger sets Employees.account_status to LOCKED and adds a row to Quarantined_Accounts.
8. The SOC analyst reviews the alert.
9. **Decision: is it a false positive?** If yes, the analyst unlocks the account. If not, the analyst reports the attempt for investigation and the account stays locked.
10. After analyzing the incident, it was documented and later submitted to the pen testers, to also carry out a recon regarding the vulnerabilities that might have caused the initial successful attack.
11. The process ends.

Data activity.

- **Create:** a row in Auth_Logs for each attempt, and rows in Security_Alerts and Quarantined_Accounts for critical events.
- **Retrieve:** FRIDAY reads earlier attempts and the risk rules when scoring, and the analyst reads the alert.
- **Update:** the account status changes to LOCKED, and back when the analyst unlocks it, along with the unlock details in Quarantined_Accounts.
- **Delete:** none. Records are kept as an audit trail.

Value. Detection and locking happen within seconds, inside the database, instead of waiting for someone to read logs later.

The UML diagram designed with Draw.io:

